Final Report

Zero Trust Implementation - Universal Rail Systems

August 27, 2024

Computer Network Security 480-AS01

Instructor

Dr. Calin Anton

REPRESENTATIVE's
Aidan Mark
Danish Kumar
Mohammad Mohammad
Mahmoud Modo

Contents

1. Report Summary **3**

2. Zero Trust Security Model **3**

2.1 What is the Zero-Trust Security Model 3

2.2. Why Do We Need the Zero-Trust Security Model? 4

1. Rise of Remote Work and BYOD (Bring Your Own Device): 4

2. Increased Sophistication of Cyber Attacks: 4

3. Cloud Adoption and Decentralized Networks: 4

4. Insider Threats: 5

5. Regulatory Compliance: 5

2.3. Trusting Users, Devices, and Traffic Under the Zero-Trust Model 5

1. Users: 5

2. Devices: 5

3. Traffic: 6

3. Survey of Current Universal Rail Systems Network **6**

3.1 Network Topology For Universal Rail Systems 6

3.2 Zero Trust Design Proposal 6

3.3 Zero Trust Implementation 7

4. Configuration And Deployment **7**

4.1 Router And Server (Our POC) 7

4.2 Network Connectivity 8

4.3 VM Server's Roles and Connectivity 8

5. Active Directory Server Deployment **9**

5.1 Active Directory Installation and Configuration 9

5.2 Certificate Authority Deployment 9

6. File Application Server Deployment **10**

6.1 IIS Reverse Proxy with mTLS 10

6.2 Security Enhancements 10

7. File Print Server Deployment **10**

7.1 Zero Trust Security Measures 10

7.2 File Sharing Services 11

8. SQL Server Deployment **11**

8.1 Enforcing mTLS 11

8.2 Access Controls 11

9. Client Remote Desktop Deployment **12**

9.1 Secure RDP Configuration 12

9.2 Firewall Configuration 12

10. Conclusion and Additional Measures **12**

Additional Measures for Consideration 13

APPENDIX

1. Network Hardware and Infrastructure **15**
1.1 Configuring Managed Switches and Routers 15
1.1.1 Network Segmentation 15
1.1.2 Port-Based Access Control with 802.1X 16
1.1.3 Layer 2 Security Features 17
1.2 Recommendations for Zero Trust Networking 18
1.2.1 Access Control Lists (ACLs) 18
1.2.3 Configuring Firewalls 19
1.3 Network Encryption 19
1.3.1 Enabling IPsec 19
1.3.2 Enforcing TLS for Management Access 20
2. Certificate Management **21**
2.1 Setting Up an Authority (CA) in Active Directory 21
2.2 Creating and Managing Certificate Templates 23
Steps to Configure Certificate Templates 23
User Certificates 24
3. Identity and Access Management **25**
3.1 Active Directory Configuration 25
3.1.1 Role-Based Access Control (RBAC) 25
3.2 Managing Service Accounts 26
3.2.1 Creating Service Accounts 26
4. Network Services and Firewalls **27**
4.1 Configuring Firewalls 27
4.1.1 Inbound and Outbound Rules 27
4.2 Enforcing IPSec 29
4.2.1 Setting Up IPSec Policies 29
5. Server-Specific Configurations **30**
5.1 Active Directory Server 30
5.1.1 Certificate Authority (CA) Configuration 30
5.2 SQL Server 30
5.2.1 Enforcing Encryption 30
5.3 File and Print Server 32
5.3.1 File Sharing Permissions 32
5.3.2 Print Security 32
5.4 Application Server 33
5.4.1 IIS Reverse Proxy Configuration 33
5.4.2 Configuring URL Rewrite for Reverse Proxy 34
3.1 Add a Reverse Proxy Rule 34
Thank you! **36**

1. Report Summary

The execution of a Zero Trust Design (ZTA) addresses a huge change in network security methodologies, underlining the guideline of "never trust, consistently check." Dissimilar to customary edge-based security models, Zero Trust expects that dangers can emerge from both inside and outside the organization, requiring ceaseless confirmation of all clients, gadgets, and assets endeavouring to get to organize resources.

Key Parts of Zero Trust Execution:
Identity Confirmation: Solid client validation utilizing multifaceted verification (MFA), job-based admittance control, and persistent checking guarantee that main approved people get entrance.

Machine Reliability: Machines are routinely assessed for consistency with security strategies, for example, working framework refreshes, antivirus insurances, and endpoint arrangements.

Miniature Division: The organization is separated into more modest portions to limit horizontal development. Each fragment implements access strategies, decreasing the effect of possible breaks.

Role-Based Access: Clients and Machines are allowed the base degree of access expected to carry out their roles, decreasing the assault surface.

Nonstop Observing: Security should be constantly screen traffic and log exercises to distinguish and alleviate irregularities.

2. Zero Trust Security Model

2.1 What is the Zero-Trust Security Model

The **Zero-Trust Security Model** is a cybersecurity framework that assumes no user, device, or system should be trusted by default, whether inside or outside the network. Instead of relying on a strong network perimeter (as in traditional security models), Zero Trust enforces strict identity verification and continuous monitoring for every access request.

Key principles of Zero Trust:

- **"Never trust, always verify":** Every request is authenticated and authorized, regardless of its origin.
- **Least privilege access:** Users and systems are granted the minimum access required to perform their roles.
- **Micro-segmentation:** Networks are divided into smaller zones to prevent unrestricted access.
- **Continuous monitoring:** Activities are logged and analyzed to detect anomalies in real time.

In essence, Zero Trust shifts the focus from "trust but verify" to "verify always" to protect against evolving cyber threats.

2.2. Why Do We Need the Zero-Trust Security Model?

The traditional perimeter-based security approach is no longer sufficient due to several factors:

1. Rise of Remote Work and BYOD (Bring Your Own Device):

- Employees access corporate networks from personal devices and unsecured networks.
- Zero Trust secures access regardless of the user's location or device.

2. Increased Sophistication of Cyber Attacks:

- Advanced threats like phishing, ransomware, and insider attacks can bypass traditional defences.
- Zero Trust minimizes potential damage by limiting lateral movement.

3. Cloud Adoption and Decentralized Networks:

- Many organizations use cloud services (e.g., SaaS, IaaS) where data resides outside the traditional network perimeter.
- Zero Trust enforces consistent security policies across on-premises and cloud environments.

4. Insider Threats:

- Employees, contractors, or compromised accounts can unintentionally or maliciously breach security.
- Zero Trust ensures that even internal users must authenticate and gain explicit permissions.

5. Regulatory Compliance:

- Many industries require stringent data protection, especially with cyber insurance.
- Zero Trust helps organizations meet compliance standards by securing access and protecting sensitive data.

By addressing these challenges, the Zero Trust model enhances resilience against modern attack vectors and ensures robust data protection.

2.3. Trusting Users, Devices, and Traffic Under the Zero-Trust Model

1. Users:

- **Authentication:** Every user must authenticate using strong methods like multi-factor authentication (MFA) before gaining access.
- **Role-based access control (RBAC):** Users are granted access only to resources necessary for their roles.
- **Continuous validation:** Even after logging in, users are continuously monitored to detect anomalies (e.g., unusual login times or locations).

2. Devices:

- **Device Compliance Checks:** Devices attempting to access the network are checked to make sure they are up-to-date, non-compromised, and following policy.
- **Endpoint Authentication:** Zero Trust ensures that only verified, secure devices are allowed to connect.
- **Quarantine Non-Compliant Devices:** Non-compliant or suspicious devices are denied access or isolated.

3. Traffic:

- **Micro-Segmentation:** Network traffic is segmented into zones, and access is granted on a need-to-know basis.
- **Encrypted Communication:** All traffic is encrypted (e.g., using TLS/SSL) to prevent eavesdropping.
- **Real-Time Monitoring:** All traffic is continuously inspected for malicious activity, even within the internal network.

3. Survey of Current Universal Rail Systems Network

3.1 Network Topology For Universal Rail Systems

Core servers, including the Active Directory (AD), SQL Server, File/Print Server (merged for our purposes), and Application Server, share the same broadcast domain, allowing unrestricted communication. User devices connect directly to the network and access resources without strict controls. External-facing applications are hosted alongside internal services and on the DMZ. Printers are integrated directly into the main network, enabling unfiltered traffic flow across devices and servers. This configuration provides functionality but lacks robust isolation or access management.

3.2 Zero Trust Design Proposal

In our project for Universal Rail Systems (URS), our team proposed the implementation of Mutual TLS (mTLS) authentication as a solution to secure east-west traffic within their network. This approach aligns with Zero Trust principles by ensuring that both servers and

clients authenticate each other through valid digital certificates during the TLS handshake process. By encrypting internal traffic, mTLS safeguards against threats like eavesdropping and man-in-the-middle (MITM) attacks. Our proposal emphasized the use of open-source or community-edition tools to establish a Certificate Authority (CA) for issuing and managing certificates, enabling a cost-effective and scalable solution. Additionally, the plan outlined steps for setup, testing, optimization, and documentation, ensuring the deployment is robust and manageable. By focusing on automation and proper access controls, the proposed solution offers a modular and secure method to enhance network security while minimizing administrative overhead.

3.3 Zero Trust Implementation

To Implement Our Proposed Solution, We required a vast understanding of the Network Traffic flow of the Universal Rail Systems. Therefore, Looking at the Structure URS provided we have 4 Physical Servers inside the Universal Rail Systems Network. In our Diagram Above we mentioned those briefly based on how we tried to virtualize them. The Remote Desktop Machine is defined by a user machine, AD server is an Active Directory Where our CA Authority will be installed Based on CA Authority all other servers will get their Certificates issued through the Active Directory Server which will lead to the Implementation of the Zero Trust throughout this Network.

4. Configuration And Deployment

4.1 Router And Server (Our POC)

The network topology illustrates a segmented network designed for Universal Rail Systems, leveraging virtualization technologies to optimize resource utilization. The router, servers, and virtual machines are hosted on a **Proxmox VE** virtualization platform, providing a robust and flexible environment for deployment.

The **VyOS router** is the network gateway, facilitating communication between the internal network, DMZ, and external Internet.

The internal servers and virtual machines, all running **Windows Server 2022**, are deployed within the Proxmox environment, ensuring scalability, high availability, and

simplified management. The Application Server (192.168.20.100) in the DMZ serves public-facing applications, isolating external traffic from internal resources.

4.2 Network Connectivity

The network design incorporates virtualized infrastructure to ensure flexibility and security:

- The internal network operates on the 192.168.1.0/24 subnet, managed by a virtualized internal switch in Proxmox, ensuring efficient data flow among critical servers.
- The DMZ switch facilitates secure communication between the public-facing Application Server (192.168.20.100) and the VyOS router, isolating internal servers from direct exposure to the Internet.
- A host machine (10.10.10.10) on the external network can connect to the VyOS router for external access testing and network management.

Virtualized internal servers, including the File Print Server and SQL Server, are configured to communicate directly with the VyOS router and other internal resources. The DMZ enforces strict security boundaries, providing controlled access to the Application Server in the public-facing zone.

4.3 VM Server's Roles and Connectivity

The virtualized environment includes multiple servers running **Windows Server 2022**, each assigned specific roles within the network:

- **Active Directory Server (192.168.10.10):** Manages authentication and domain services.
- **File Print Server (192.168.10.11):** Provides shared printing and file storage services.
- **SQL Server (192.168.10.12):** Hosts the database for internal and external applications.
- **Application Server (192.168.10.15):** Facilitates internal application services.
- **Virtual Machine (192.168.10.100):** Configured for isolated testing and development, connected via the F0/6 port of the internal switch.

The **Proxmox VE** platform enables efficient allocation of hardware resources, while the VyOS router ensures seamless connectivity and routing between the virtualized network segments.

5. Active Directory Server Deployment

The Active Directory (AD) server plays a pivotal role in the Zero Trust implementation by managing user identities, device authentication, and policy enforcement. As part of this project, we configured a dedicated Windows Server 2022 instance to act as the AD Domain Controller (DC) and Certificate Authority (CA).

5.1 Active Directory Installation and Configuration

- **Domain Controller Role**:
  - The AD server (192.168.10.10) was configured as the primary DC for the domain urs.local.
  - DNS services were set up to point internally, with Google DNS servers (8.8.8.8 and 8.8.4.4) configured as forwarders for external name resolution.

5.2 Certificate Authority Deployment

1. **Enterprise Root CA**:
   - The CA was installed on the AD server to issue certificates for user, machine, and service authentication.
   - Certificate templates were customized to support Client Authentication and Server Authentication.
2. **Certificate Distribution**:
   - Certificates were automatically distributed to domain-joined machines using Group Policy.
   - Non-compliant or untrusted devices without valid certificates were denied access, adhering to mTLS principles.

6. File Application Server Deployment

The Application Server (192.168.10.15) is a critical component that facilitates secure internal application hosting while adhering to Zero Trust principles. It operates behind the VyOS router in a segmented zone for added security.

6.1 IIS Reverse Proxy with mTLS

1. **IIS Role Installation**:
    - IIS was configured as a reverse proxy to terminate HTTPS connections and enforce client certificate authentication.
2. **Mutual TLS Configuration**:
    - IIS required valid client certificates for all incoming connections, ensuring only trusted users and devices could access the applications.

6.2 Security Enhancements

- **Firewall Rules**:
    - Restricted traffic to port 443 (HTTPS) from specific subnets (e.g., Remote Desktop VMs).
    - Blocked unnecessary inbound and outbound traffic.
- **Role-Based Access Control**:
    - Service accounts were created with minimal privileges to run the web applications securely.

7. File Print Server Deployment

The File Print Server (192.168.10.11) was deployed to provide centralized file storage and print services while mitigating security risks associated with printers, often regarded as a weak link in enterprise security.

7.1 Zero Trust Security Measures

1. **VLAN Isolation**:
    - Printers were isolated in their own VLAN, ensuring they could only communicate with the print server.
2. **mTLS Middleware**:

- PaperCut NG was installed on the print server to enforce authentication for all print jobs.
- Communication between user devices and the server was secured with HTTPS and client certificates.

7.2 File Sharing Services

1. **Access Control**:
   - Shared folders were configured with NTFS and share-level permissions, restricting access to domain users.
   - Audit policies were enabled to monitor access attempts.
2. **Firewall Rules**:
   - The server only allowed connections from internal IP ranges and blocked all external access.

8. SQL Server Deployment

The SQL Server (192.168.10.12) was configured to securely host databases for internal applications. Zero Trust principles were enforced through strict access controls and encryption.

8.1 Enforcing mTLS

1. **Certificate-Based Authentication**:
   - The SQL Server was configured to use certificates issued by the internal CA.
   - Only devices with valid client certificates could establish connections.
2. **Encrypted Traffic**:
   - Forced encryption was enabled for all SQL connections using the Force Encryption option in SQL Server Configuration Manager.

8.2 Access Controls

1. **Firewall Restrictions**:
   - Port 1433 was open only to the Application Server's IP (192.168.10.15).
   - All other traffic was blocked at the server and network levels.
2. **Service Account Integration**:

- The application queried the database using a dedicated, minimally privileged service account (sqlSVC).

9. Client Remote Desktop Deployment

To facilitate secure user access, Remote Desktop Protocol (RDP) was implemented with strict Group Policy configurations.

9.1 Secure RDP Configuration

1. **Certificate-Based RDP**:
   - Users could only connect to Remote Desktop VMs using certificates issued by URS-ROOT-CA.
   - RDP sessions required strong user authentication through AD.
2. **Group Policy Hardening**:
   - Clipboard sharing and drive mapping were disabled to prevent unauthorized data exfiltration.
   - Non-domain devices were denied RDP access.

9.2 Firewall Configuration

1. **RDP Port Restriction**:
   - Traffic to port 3389 was restricted to trusted subnets.
2. **Device Health Checks**:
   - Network Access Control (NAC) was used to ensure connecting devices met security requirements (e.g., antivirus, patches).

10. Conclusion and Additional Measures

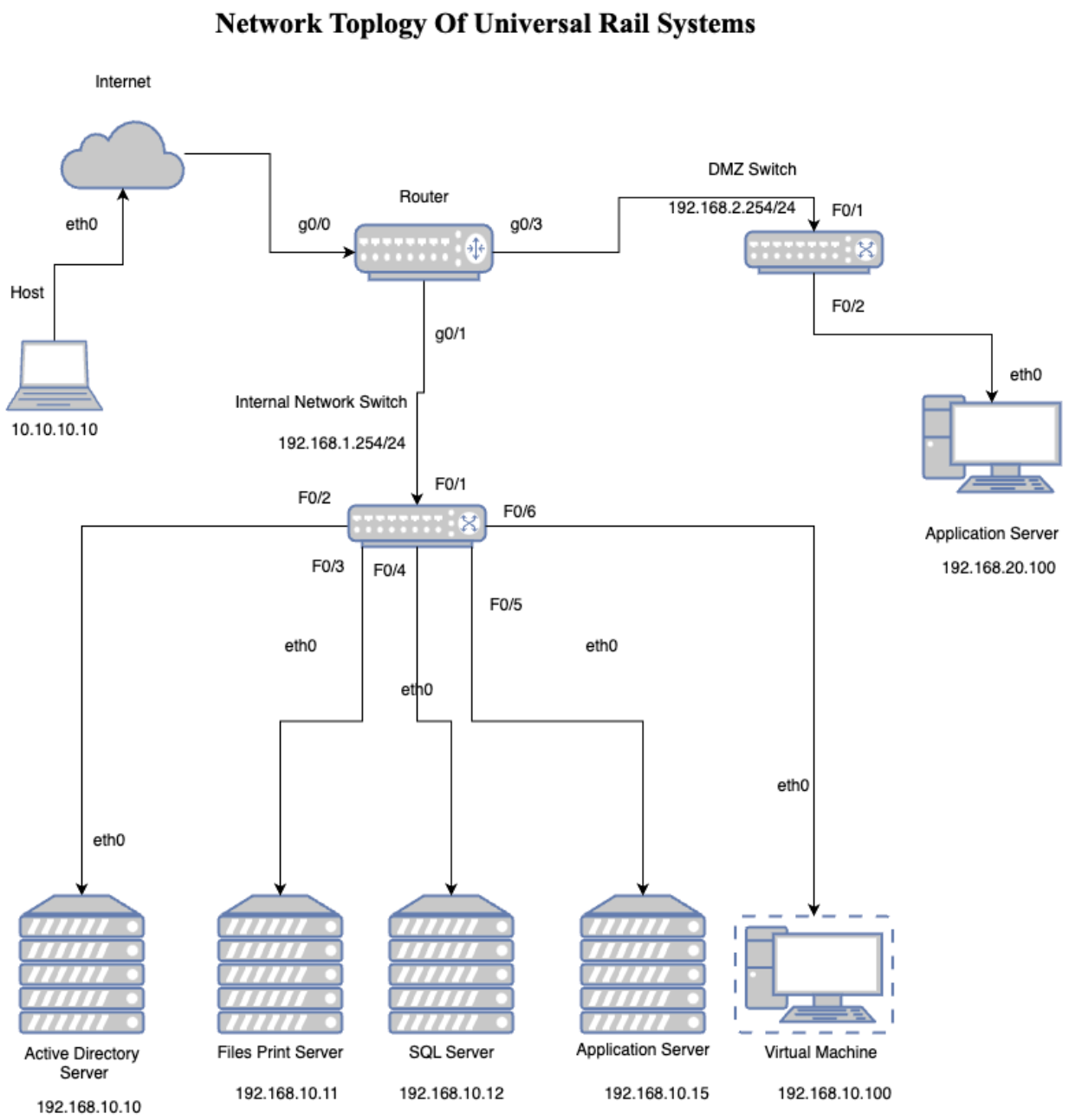
The Zero Trust implementation at Universal Rail Systems (URS) demonstrates a robust approach to modern cybersecurity challenges. By enforcing mutual TLS, strict access controls, and continuous monitoring, the project successfully reduces the attack surface while ensuring secure access to critical resources.

Additional Measures for Consideration

1. **Network Access Control (NAC)**:
    - Implement NAC to quarantine non-compliant devices dynamically.
2. **802.1X:**
    - Certificates at the network level.
3. **SIEM Integration**:
    - Centralize log collection and analysis for enhanced threat detection.
4. **Regular Penetration Testing**:
    - Conduct periodic tests to identify vulnerabilities.
5. **User Awareness Training**:
    - Educate users on security best practices to minimize human error.

Appendix

This is an extended section dedicated to configuration specifics.



1. Network Hardware and Infrastructure

Properly configuring network hardware is foundational to implementing Zero Trust principles. This section provides detailed guidance on leveraging enterprise-grade hardware, like Cisco managed switches and routers, to segment the network, enforce policies, and enable secure communication. While our POC utilized VyOS as a generic router, URS hardware should be more robust and full of features. From the information that we gathered about Cisco hardware, here are some steps that can be taken to configure it.

1.1 Configuring Managed Switches and Routers

1.1.1 Network Segmentation

Network segmentation is critical for limiting lateral movement in case of a breach. It isolates resources into distinct zones (e.g., DMZ, production, test environments).

Use SSH or the console to connect to the switch and create VLANs for specific network segments:

```
ssh admin@<switch-ip>
configure terminal
vlan 10
name Internal_Network
exit
vlan 20
name DMZ
exit
vlan 30
name Printers
exit
```

Assign switch ports to their respective VLANs:

```
interface GigabitEthernet0/1
switchport mode access
switchport access vlan 10
exit
interface GigabitEthernet0/2
switchport mode access
switchport access vlan 20
exit
```

Configure trunk ports to carry multiple VLAN traffic to the router:

```
interface GigabitEthernet0/24
switchport mode trunk
switchport trunk allowed vlan 10,20,30
exit
```

Commands to confirm:

```
show vlan brief
show interfaces trunk
```

1.1.2 Port-Based Access Control with 802.1X

802.1X makes sure that only authenticated devices can connect to the network, which provides an additional layer of Zero Trust security.

While we did not cover this in our POC, it can be very beneficial to setup. Using a RADIUS server and enabling 802.1X on ports can help protect this layer effectively.

1.1.3 Layer 2 Security Features

To prevent attacks at the data link layer, consider the following:

1. **Restrict the number of devices that can connect to a port (example):**

```
interface GigabitEthernet0/1

switchport port-security

switchport port-security maximum 2

switchport port-security violation restrict

exit
```

2. **Dynamic ARP Inspection (DAI) to mitigate ARP spoofing attacks:**

```
ip arp inspection vlan 10
```

3. **Spanning Tree Protocol (STP) to protect against loops and rogue device:**

```
spanning-tree portfast bpduguard enable
```

1.2 Recommendations for Zero Trust Networking

1.2.1 Access Control Lists (ACLs)

ACLs restrict traffic flow between network segments and enforce least privilege access. Allow traffic only between authorized devices:

```
access-list 100 permit tcp host 192.168.10.15 host 192.168.10.12
eq 1433
```

```
access-list 100 deny ip any any
```

Also apply to interfaces like the DMZ:

```
interface GigabitEthernet0/2 ip access-group 100 in
```

1.2.2 Implementing Network Access Control (NAC)

Network Access Control enforces device compliance before allowing access to the network.

Recommended Tools

- Cisco ISE (Identity Services Engine)
- Third-party NAC Solutions like Aruba ClearPass or Microsoft NPS can also be integrated with Cisco switches

1.2.3 Configuring Firewalls

Firewalls enforce security policies at both the network perimeter and internal segments. Create zones for different network areas (e.g., internal, dmz, public).

Allow traffic from internal to DMZ for application communication:

```
zone-pair security Internal-to-DMZ source internal destination
dmz

match protocol tcp

action inspect
```

1.3 Network Encryption

1.3.1 Enabling IPsec

IPsec provides encrypted communication between VLANs or remote endpoints.

```
crypto ipsec transform-set TRANS_ESP esp-aes 256 esp-sha-hmac

crypto map MAP 10 ipsec-isakmp

set peer 192.168.20.1

set transform-set TRANS_ESP

match address 101
```

Bind the IPsec configuration to an interface:

```
interface GigabitEthernet0/0

crypto map MAP
```

1.3.2 Enforcing TLS for Management Access

Secure the management plane by requiring HTTPS and SSH for administrative access to the hardware:

```
ip http secure-server

ip ssh version 2

line vty 0 4

transport input ssh
```

Limit management access to specific IPs:

```
ip access-list standard MGMT

permit 192.168.1.100

line vty 0 4

access-class MGMT in
```

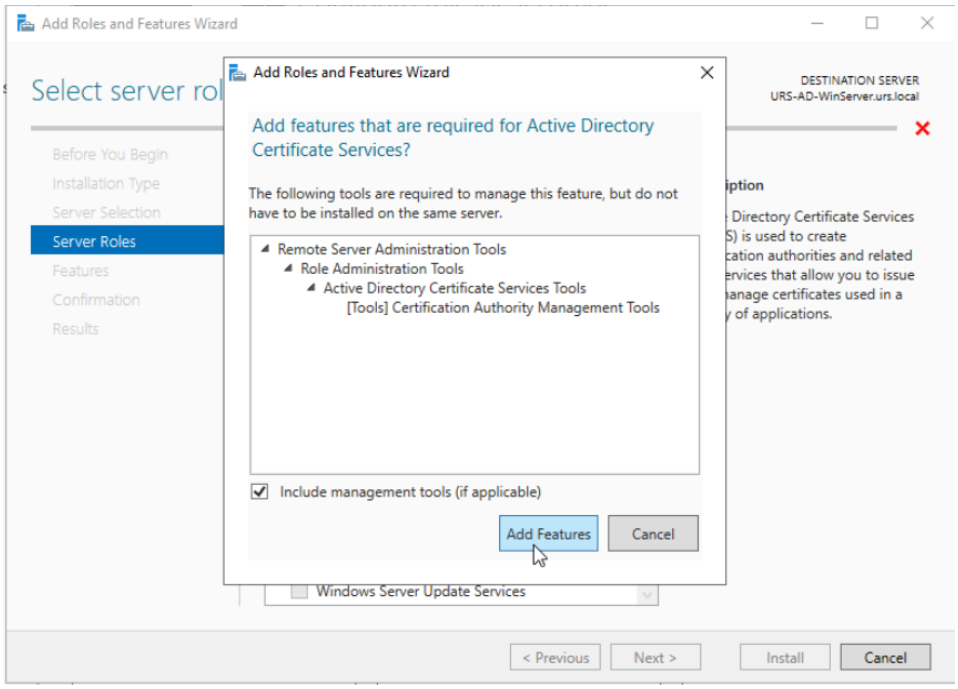
2. Certificate Management

A certificate management system is critical for enforcing Zero Trust principles. Certificates are used to verify the identity of users, devices, and servers, enabling mutual TLS (mTLS) authentication, encrypted communication, and secure access control. This section provides steps for setting up and managing certificates in your environment (hopefully).

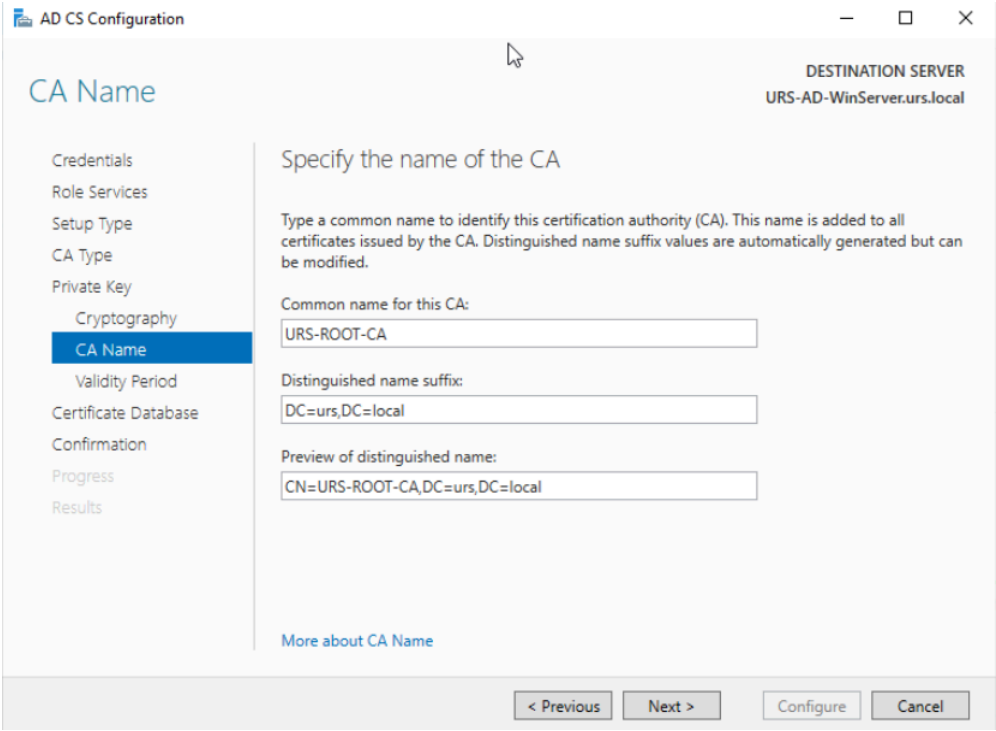
2.1 Setting Up an Authority (CA) in Active Directory

An Enterprise Root CA issues and manages certificates within the organization. For this implementation, Active Directory Certificate Services (AD CS) is used.

1. **Install AD CS Role**:
    - Access **Server Manager** on the domain controller.
    - Add the **Active Directory Certificate Services** role.
    - Select the **Certification Authority** role service during installation.



2. **Configure CA as Enterprise Root**:
    - Launch the **AD CS Configuration Wizard**.
    - Choose **Enterprise CA** and **Root CA** as the deployment type.



    - Create a new private key and configure the hash algorithm (e.g., SHA-256) and key length (e.g., 2048 bits).
3. **Publish the Root Certificate**:
    - Open the **Certification Authority** console.
    - Right-click the CA name > **All Tasks > Publish**.
    - Publish the Root Certificate to Active Directory to ensure all domain-joined devices trust the CA.
4. **Backup the CA**:
    - Regularly back up the CA database and private key:

```
certutil -backupDB "C:\CA_Backup"

certutil -backupKey "C:\CA_Backup"
```

2.2 Creating and Managing Certificate Templates

Certificate templates allow customization of certificates for specific use cases, such as client authentication, server authentication, and secure email.

Steps to Configure Certificate Templates

1. **Create a Custom Template**:
    - Open the **Certificate Templates Console**.
    - Right-click an existing template (e.g., **Web Server**) > **Duplicate Template**.
    - Edit the template properties:
        - **General Tab**: Rename the template (e.g., WebServer_ClientAuth).
        - **Extensions Tab**: Enable Client Authentication and Server Authentication.
        - **Security Tab**: Add groups (e.g., Domain Computers, Domain Users) with **Enroll** permissions.
2. **Enable the Template on the CA**:
    - Open the **Certification Authority** console.
    - Right-click **Certificate Templates** > **New** > **Certificate Template to Issue**.
    - Select the newly created template.
3. **Distribute Certificates Automatically**:
    - Navigate to:
      Computer Configuration > Policies > Windows Settings > Security Settings > Public Key Policies > Certificate Services Client - Auto-Enrollment
    - Set Configuration Model to Enabled

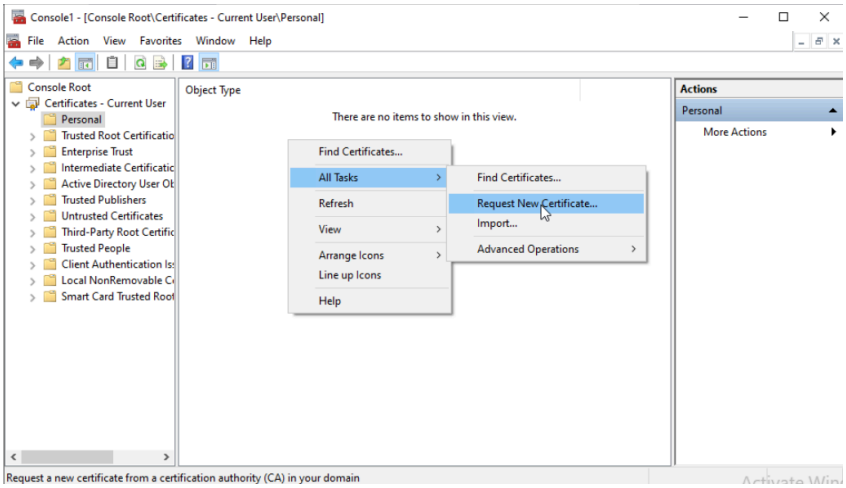
Verify Certificate Installation:

- On a domain-joined machine, open **MMC** > Add Snap-In > **Certificates** > **Local Computer**
- Confirm the presence of the machine certificate under **Personal > Certificates**

User Certificates

User certificates authenticate individual users. These certificates are useful for RDP logins, secure email, and application access.

1. Manual Enrollment for Specific Users:
    - On a user's workstation:
        - Open MMC > **Add Snap-In** > **Certificates** > My User Account.
        - Navigate to Personal > **Certificates** > **All Tasks** > **Request New Certificate.**



        - Select the appropriate template (e.g., UserAuth).
2. Automatic Enrollment via Group Policy:
    - Configure the GPO as described in 2.3 Machine Certificates.
    - Assign the certificate template to user accounts.

Configure RDP for Certificate Authentication (mTLS):

Open Group Policy Management and navigate to:

Computer Configuration > Policies > Administrative Templates > Windows Components > Remote Desktop Services > Remote Desktop Session Host > Security

Enable **Require use of specific security layer for remote connections** and set it to **SSL (TLS 1.0)** or higher.

3. Identity and Access Management

Identity and access management (IAM) is a core component of the Zero Trust model with the focus on users. This section outlines how to configure Active Directory for role-based access control, service account management, and group policy enforcement.

3.1 Active Directory Configuration

As you know, the Active Directory server handles all the identity management across the network. While much of this section is probably already covered, we'll include a brief review.

3.1.1 Role-Based Access Control (RBAC)

RBAC ensures that users and devices have the minimum permissions required for their roles. It is a good idea to review these controls and make sure they align with company policy.

1. **Define Roles**:
    - Identify roles within your organization (e.g., Database Administrator, Marketing User).
2. **Create Security Groups**:
    - In ADUC, create security groups for each role:
        - Example: SQL_Admins, Marketing_ReadOnly.
    - Assign group members based on their roles.
3. **Assign Permissions**:
    - Use group memberships to manage access to resources:
        - **File Shares**: Configure NTFS permissions based on groups (e.g., Read, Modify).
        - **Applications**: Use group policies to control access to software and network shares.

3.2 Managing Service Accounts

Service accounts are non-interactive accounts used by applications and services. Proper management is crucial to minimize security risks.

3.2.1 Creating Service Accounts

1. **In ADUC**:
    - Create a new user for each service (e.g., sqlSVC, printSVC).
    - Place service accounts in the Service Accounts OU.
2. **Restrict Permissions**:
    - Be sure to deny interactive logon for service accounts:
        - Open the account properties > **Account** tab.
        - Check **Logon Workstations** and restrict to specific machines.
        - Handle server specifics such as SQL service and printer service accounts.

4. Network Services and Firewalls

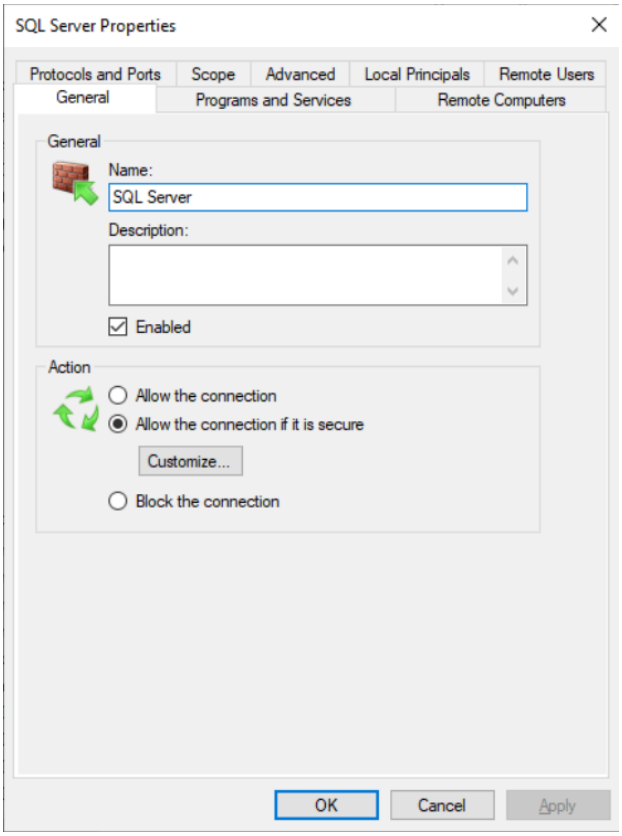
This section outlines best practices for securing network traffic through firewalls, enforcing access controls, and ensuring encrypted communication across all network layers.

4.1 Configuring Firewalls

Micro-segmentation is the name of the game. Configuring both perimeter and internal firewalls ensures comprehensive Zero Trust. Remember, each firewall needs to be tailored to the specific system.

4.1.1 Inbound and Outbound Rules

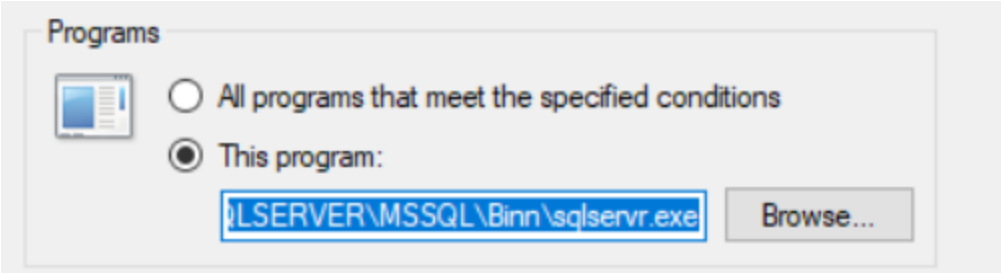
1. **Restrict Inbound Traffic**:
    - Allow access only to essential services (e.g., SQL, RDP) and only from trusted sources.
2. **Example Rule (SQL Server)**:



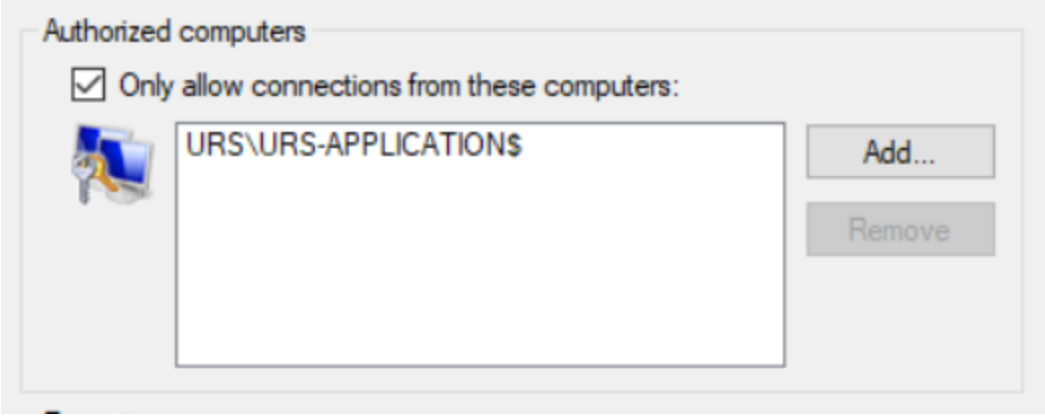
Allow the connection if it is secure

Enables IPsec and ensures all traffic is encrypted.

Enable the specific application for this rule. This prevents the SQL server from being spoofed.



Finally, ONLY allow specific machines and their respective service accounts



3. **Restrict Outbound Traffic**:

- Block unnecessary outbound traffic to prevent data exfiltration or misuse.

4.2 Enforcing IPSec

Internet Protocol Security (IPSec) ensures secure communication between devices by encrypting traffic at the network layer. This setup adheres to the remote desktop farm.

4.2.1 Setting Up IPSec Policies

1. **Open Windows Firewall with Advanced Security**:
    - Navigate to **Inbound Rules > New Rule**.
2. **Configure Authentication Rules**:
    - Add a new IPSec rule to require machine authentication:
        - **First Authentication**: Use computer certificates (e.g., issued by URS-ROOT-CA).
        - **Second Authentication**: Use Kerberos.
3. **Apply IPSec Encryption**:
    - Create a connection security rule:
        - **Rule Type**: Isolation.
        - **Endpoints**: Add trusted IP ranges (e.g., 192.168.10.0/24).
4. **Test IPSec Policies**:
    - Use ping and tracert to ensure packets are encrypted and secured.

NOTE: IPsec can also be enabled on a network switch. See your switch manual for details.

5. Server-Specific Configurations

Each server in the network plays a unique role. This section outlines the key configurations for individual servers, focusing on secure access, certificate enforcement, and role-specific optimizations.

5.1 Active Directory Server

The Active Directory (AD) server is the cornerstone of identity and access management in the Zero Trust framework. It manages authentication, authorizations, and policies across the network.

5.1.1 Certificate Authority (CA) Configuration

1. **Install and Configure the Enterprise Root CA**:
    - Refer to **Section 2.1** for detailed steps.
2. **Issue Certificates for Critical Resources**:
    - Enroll certificates for servers (SQL, Application, File/Print).
    - Use the **Web Server** template for services that require HTTPS.
3. **Publish Certificate Revocation List (CRL)**:
    - Ensure CRLs are accessible via HTTP or LDAP to validate certificate statuses.

5.2 SQL Server

The SQL Server is the database backbone for critical applications. It must enforce encryption, role-based access control, and restricted connectivity.

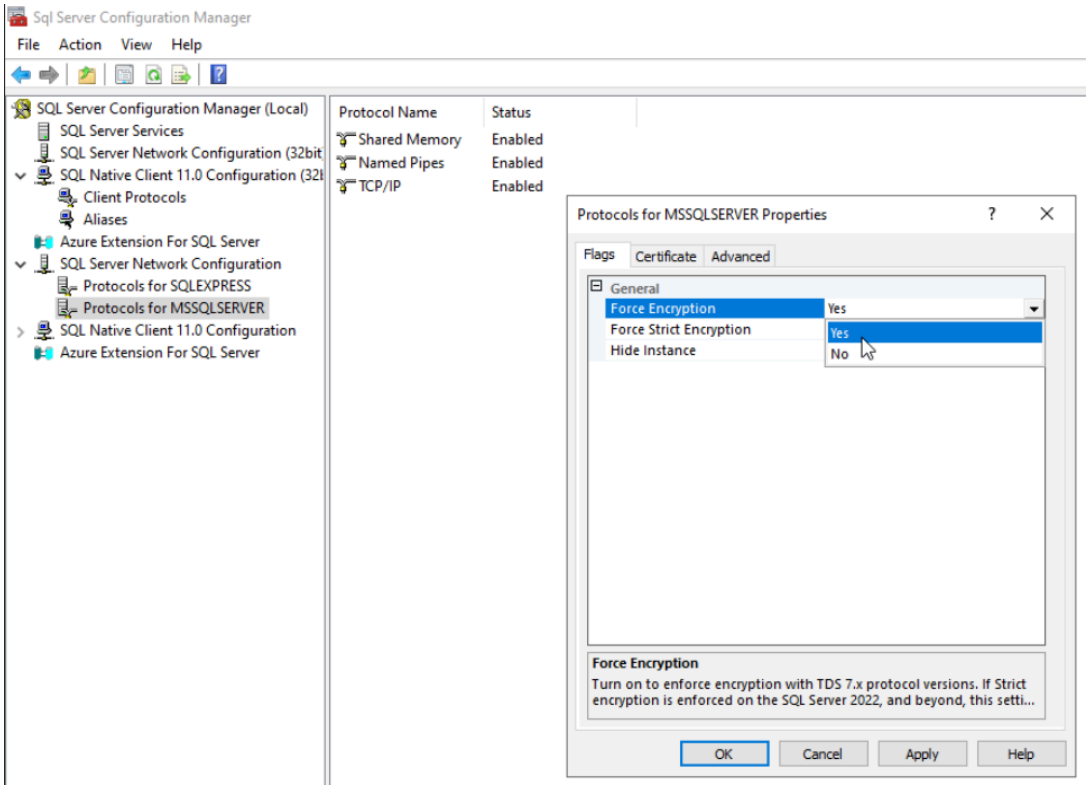
5.2.1 Enforcing Encryption

1. **Install and Bind a Server Certificate**:
    - Refer to **Section 2.1** for certificate setup.
    - Bind the certificate in **SQL Server Configuration Manager** under:

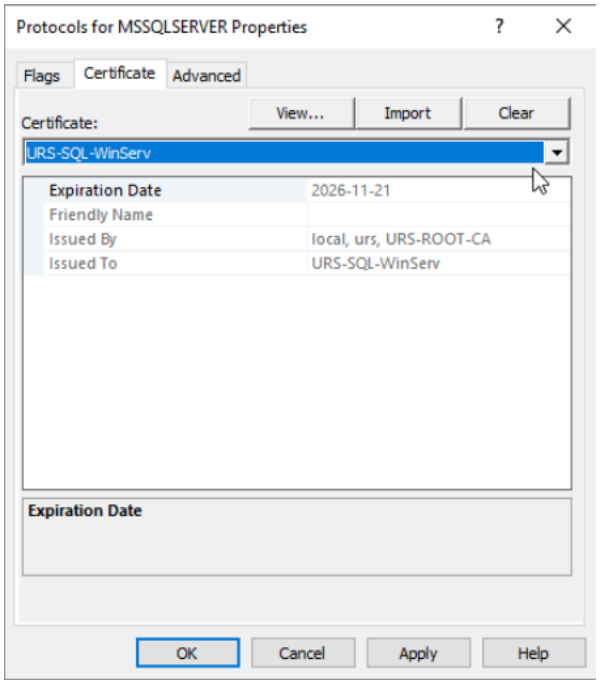
Protocols for MSSQLSERVER > Properties > Certificate

Force Encryption for Connections:

- Enable **Force Encryption** in SQL Server Configuration Manager.



- Include the certificate for authentication



5.3 File and Print Server

The File and Print Server provides shared storage and printing capabilities. Printers are often overlooked in security configurations but can be significant attack vectors. While Zero Trust applies equally to everything, we *really* don't trust printers.

5.3.1 File Sharing Permissions

1. **Configure NTFS Permissions**:
    - Assign specific groups (e.g., Marketing, IT) permissions to shared folders.
2. **Enable Auditing**:
    - Track access attempts for sensitive directories.

5.3.2 Print Security

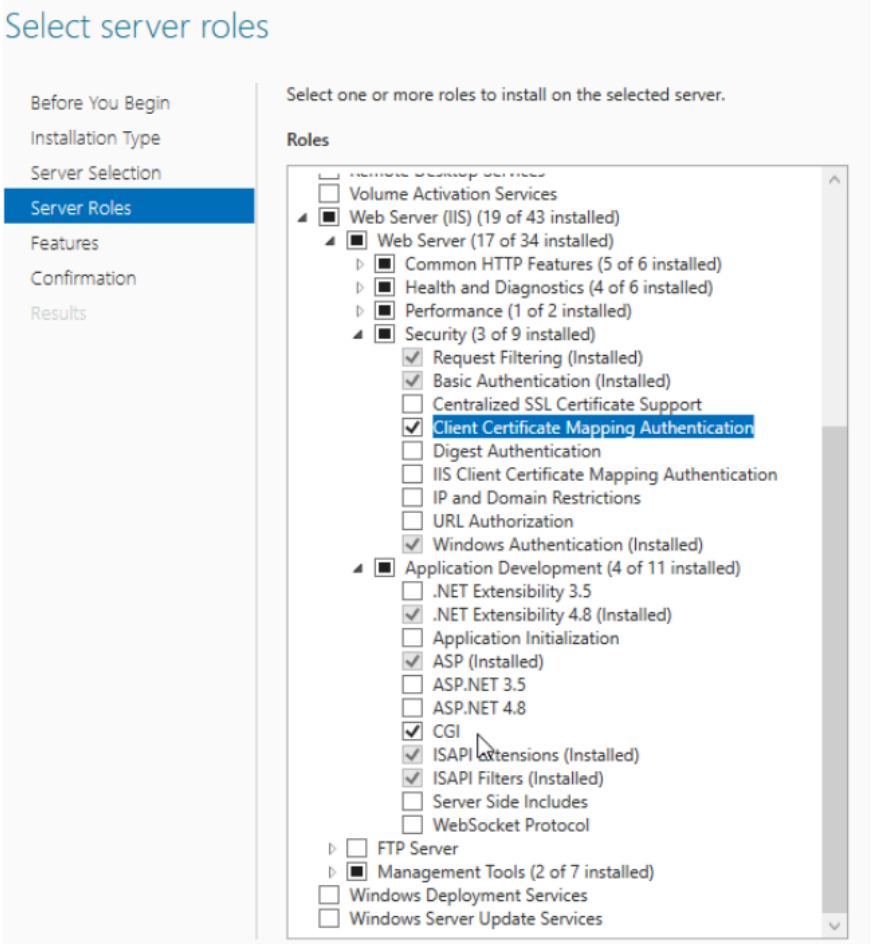
1. **Middleware for mTLS**:
    - Deploy PaperCut NG or another middleware solution to enforce certificate-based print job authentication.
    - This application may not be free. However, it might be the only secure solution for a large organization.
2. **Firewall Rules**:
    - Give the printer its own VLAN
    - Restrict traffic to and from printers:
        - Allow traffic only from the print server to the printer VLAN.
        - Deny direct user-to-printer communication.

5.4 Application Server

The application server hosts web applications and interfaces with the SQL server. It requires strict access controls and HTTPS enforcement.

5.4.1 IIS Reverse Proxy Configuration

1. **Install IIS**:
    - Add the **Web Server (IIS)** role with the **URL Rewrite** and **Application Request Routing (ARR)** features.



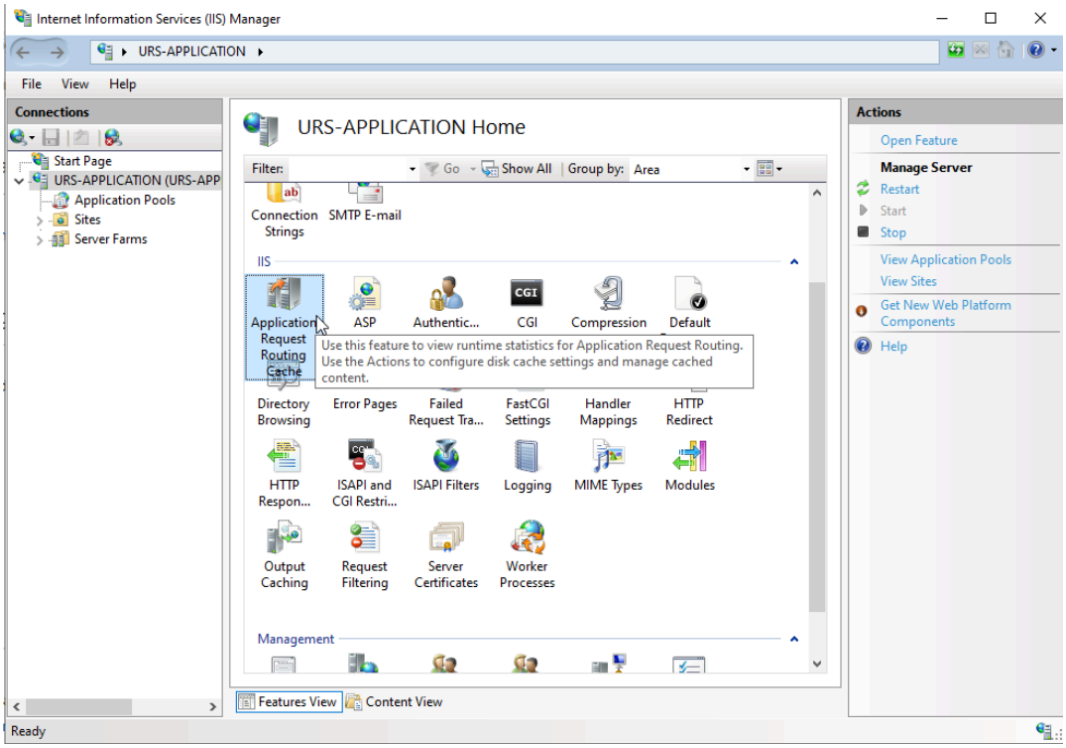
2. **Configure HTTPS**:
    - Bind a certificate to port 443 in IIS Manager. This is done by right-clicking the site. Be sure to use the server certificate!
    - Enable **Require SSL** and **Require Client Certificates** under **SSL Settings**.

5.4.2 Configuring URL Rewrite for Reverse Proxy

The URL Rewrite module allows IIS to forward requests to a backend server while maintaining the HTTPS connection for clients.

3.1 Add a Reverse Proxy Rule

1. **Enable ARR (Application Request Routing):**
    - In IIS Manager, click the server name.
    - Open **Application Request Routing Cache**.



    - Click **Server Proxy Settings** in the right pane and enable **Enable Proxy**.

2. **Configure URL Rewrite**:
    - Open the site's **URL Rewrite** settings.
    - Add a new inbound rule:
        - **Match URL**: (.*).
        - **Action**:
            - Action Type: **Rewrite**.
            - Rewrite URL: http://127.0.0.1:32400/{R:1}.
        - Add a condition:
            - Input: {HTTPS}.
            - Check if input **matches the pattern**: ^ON$.
3. **Test Reverse Proxy**:
    - Open a browser and navigate to the site's URL.
    - Ensure the backend application responds correctly.
    - Enable SSL offloading when using a server with HTTP only
    - Use a tool like **IIS Crypto** to disable older protocols (e.g., TLS 1.0, TLS 1.1) and enable only TLS 1.2 or 1.3.

Anything web-facing should be using HTTPS. IIS can be utilized here for easy certificate management. It integrates well with the Microsoft CA we setup earlier.

Thank you!

We had lots of fun working on this! Please feel free to reach out to us if you have any questions!

Aidan Mark:
abmark88@gmail.com
www.linkedin.com/in/akimbo-html

Danish Kumar:
danishd@mymacewan.ca
https://www.linkedin.com/in/danish-kumar-9128651b5/